

Industrial Security (Bachelor)

Solution Sheet – Section 09 Standards, Compliance, Governance

Goal. Each solution below gives a defensible model answer with a short rubric hint at the end. Award partial credit for any answer that cites the correct regulation identifier and the correct enforcement date, even if the operational details differ from the model.

Solution

Exercise 9.1 – Stuttgart auto-parts factory. NIS2 (Directive (EU) 2022/2555) applies: manufacture of motor vehicles and parts is listed in Annex II and the site is well above the medium-enterprise threshold (50 staff or EUR 10 M turnover), making it an *important entity*. KRITIS (BSI-KritisV) does *not* apply: automotive parts manufacturing is not one of the listed KRITIS sectors regardless of size — KRITIS covers energy, water, food, IT/telecom, finance, transport, health, waste, and public administration. The CRA (Regulation (EU) 2024/2847) applies to the smart torque wrench: it is a network-connectable “product with digital elements” placed on the EU market, so the factory acts as *manufacturer* in the CRA sense and inherits SBOM, vulnerability-handling and update duties. IEC 62443 is not statutorily required but is almost certainly contractual — German OEMs typically push 62443-2-4 supplier requirements down to their tier-1 suppliers, and a 62443-2-1 CSMS is the cheapest way to satisfy NIS2 “appropriate measures”. One-sentence conclusion: *NIS2 + CRA are mandatory; 62443 is de-facto mandatory via OEM contracts; KRITIS is not in scope.*

Rubric. Two points for correctly excluding KRITIS with reasoning; one each for NIS2 Annex II, CRA product scope, and the contractual-not-statutory 62443 framing.

Solution

Exercise 9.2 – 110 kV substation SL-T. *Protection zone:* SL-T 3. Consequence is loss of selective tripping and possible cascading outage; threat actor must be assumed to be a sophisticated, well-resourced adversary (Industroyer/Industroyer2 demonstrate the capability); modern IEC 61850 IEDs can support SL-3 if patched and configured. *Station control zone:* SL-T 3 on the same reasoning — a compromised HMI can issue real switching commands. *Engineering zone:* SL-T 3 because engineering tools are the natural pivot to the protection IEDs (compare the Industroyer kill chain); apply strict change-control and offline tool-laptops. *iDMZ:* SL-T 2 is appropriate — it is internet-adjacent and faces casual to moderately resourced attackers, but only replicas and brokered sessions live there. SL-T 4 (nation-state resistance) is disproportionate for a regional distribution substation and is realistically unattainable on commodity IEDs; one would push to SL-T 4 only on transmission-level installations of national strategic importance. We would deliberately cap the iDMZ at SL-T 2 to avoid over-engineering and keep the protection zone at SL-T 3 rather than 4 because the field devices simply cannot enforce SL-4 cryptographic primitives.

Rubric. Award full marks for any defensible per-zone SL-T that cites consequence, actor, and feasibility; deduct for assigning SL-T 4 without acknowledging IED limitations.

Solution

Exercise 9.3 – 62443-2-1 programme elements. Five canonical elements with sample artefacts:

1. *Risk analysis* – a 62443-3-2 zone-and-conduit risk register, signed by the OT Security Lead, with per-zone SL-T and review date.

2. *System architecture* – an up-to-date network diagram in the CMDB showing zones, conduits, and firewall rule references, regenerated from inventory data quarterly.
3. *Security policies* – a numbered *OT Acceptable Use Policy v2.1* with version history and an annual sign-off log.
4. *Patch management* – a quarterly patch-status report listing every PLC/HMI by firmware version, with SLA aging buckets and exceptions formally accepted by the plant manager.
5. *Incident response and training* – the most recent tabletop-exercise report (date, scenario, participants, lessons learned) plus an attendance log for the OT-awareness training of operators and engineers.

Rubric. One point per element + concrete artefact; deduct for generic answers (“a policy”, “documentation”).

Solution

Exercise 9.4 – testing a vendor’s “62443 compliant” claim. Three questions:

1. *Which part of 62443 and which Security Level?* Pass: “IEC 62443-4-2 certified to SL-2 capability”. Fail: “62443 compliant” with no part or SL named.
2. *Which of the seven Foundational Requirements were assessed, and at which SL did each pass?* Pass: a one-page matrix listing FR1–FR7 with SL achieved per FR (typically SL-2 across the board, possibly SL-1 on *Resource Availability*). Fail: silence on per-FR results, which usually hides one or two requirements that did not pass.
3. *Who certified it, when, and is the certificate still valid?* Pass: a named certification body (e.g. TÜV SÜD, exida, ISASecure CSA programme), an issue date, an expiry date, and the firmware/hardware revision in scope. Fail: a self-declaration without a third-party certificate, or a certificate that names a firmware version older than the one being shipped.

Rubric. Full marks if all three questions probe part-and-SL, per-FR results, and certifier evidence; partial credit otherwise.

Solution

Exercise 9.5 – NIS2 Article 23 timeline. Incident detected Friday, 20 February 2026 at 18:30 (CET). Article 23 deadlines:

- *Early warning – 24 h:* by Saturday, 21 February 2026, 18:30. Submit to BSI as the national CSIRT via the MeldeM/BSI reporting portal; the early warning may be terse (suspected significant incident, whether cross-border, suspected criminal/state actor).
- *Incident notification – 72 h:* by Monday, 23 February 2026, 18:30. Submit to BSI with an initial assessment of severity, impact, and indicators of compromise.
- *Final report – 1 month:* by Friday, 20 March 2026. Submit to BSI with root-cause analysis, mitigation taken, and lessons learned.

Practical pitfalls: the 24-hour clock runs over the weekend regardless of staffing; “without undue delay” has been interpreted by national CSIRTs as “ASAP, and certainly before the 24-hour ceiling”; reporting language is typically German for BSI submissions; and an interim 1-month update may be required if the incident is still ongoing.

Rubric. Each deadline date+time correct: one point; BSI named as recipient: one point; at least one practical pitfall identified: one point.

Solution

Exercise 9.6 – C2M2 self-assessment. Sample (your university lab will vary):

- *Asset, Change, and Configuration Management*: score **1** (*performed informally*). An asset list exists in a spreadsheet maintained by one TA; there is no automated discovery, no formal change process, and the inventory is rebuilt each semester. Improvement: introduce a lightweight CMDB (NetBox or even a versioned YAML file in Git) so changes leave an audit trail → would reach level 2.
- *Identity and Access Management*: score **1**. Shared lab credentials are common; SSH keys exist but are not rotated; no MFA on the jump host. Improvement: per-student SSH keys with quarterly rotation and an authenticated jump host → would reach level 2.
- *Incident Response*: score **0** (*not performed*). No playbook, no on-call rotation, no tabletop has ever been run for the lab. Improvement: write a one-page playbook for “lab compromise suspected” and run a 90-minute tabletop with staff and TAs → would reach level 1.

Rubric. Award marks for honest, evidence-cited self-assessment; full marks require each improvement to be both concrete and feasible in one semester.

Solution

Exercise 9.7 – CRA duties on a connected-PLC manufacturer. Three duties from Regulation (EU) 2024/2847:

1. *Security by design and CE marking for cybersecurity* – the PLC must meet the essential cybersecurity requirements of Annex I (secure-by-default configuration, vulnerability handling, integrity protection) and be CE marked accordingly. Enforceable for new placements on the EU market from **11 December 2027**. Evidence: technical file, EU declaration of conformity, CE mark on the product.
2. *SBOM and security-update provision over the support period* – the manufacturer must maintain an SBOM (machine-readable, e.g. CycloneDX or SPDX) and supply free security updates for the expected support period (default 5 years). Enforceable from **11 December 2027**. Evidence: published SBOM and a documented security-update policy with delivery channel.
3. *Coordinated vulnerability disclosure and 24/72-hour reporting to ENISA* – the manufacturer must operate a CVD process and report *actively exploited* vulnerabilities to ENISA within 24 h (early warning) and a notification within 72 h, plus a final report within 14 days. This duty bites earlier than the rest: **from 11 September 2026** (the vulnerability-reporting provisions in CRA Articles 14–15 apply 21 months after entry into force on 11 December 2024). Evidence: published `security.txt` or PSIRT contact, CVD policy, ENISA single-reporting-platform submissions.

Rubric. Full marks if all three duties are correctly attributed to the manufacturer, the 2027 enforcement date is identified, and the earlier 2026 vulnerability-reporting date is called out; partial credit if 2027 is correct but the September 2026 staging is missed.

Solution

Exercise 9.8 – compliance vs. security. *Scenario 1 (compliant but insecure).* A small US generation cooperative passes a NERC CIP-005 audit with a documented Electronic Security Perimeter and approved firewall rule set, but the rule set contains an “any/any/permit” for vendor remote support that goes unreviewed for 18 months. The checklist asked *is there an*

ESP? but never *is the rule set least-privilege and reviewed?* — a sophisticated attacker who phishes the vendor’s account walks straight into the BES Cyber System without violating a single CIP requirement.

Scenario 2 (reasonably secure but not fully boxed). A 30-MW community hydro plant runs serial-only field links, a fully air-gapped engineering laptop, immutable offline backups verified monthly, and a one-page IR playbook — but it has *no formal* 62443-2-1 CSMS, no signed policies, no training-attendance ledger. A 2-1 auditor would mark several boxes red, yet the residual risk is genuinely small because there is no network path for a remote attacker and the recovery time is dominated by physical replacement, not data restoration.

Conclusion. Checklists are necessary but never sufficient: read them as a floor, not a ceiling, and pair every audit finding with a question about the threat the control is supposed to defeat.

Rubric. Each scenario worth one point if the specific checklist and the specific gap (or skipped box) are both named; one point for the closing-sentence reflection.

Solution

Exercise 9.9 – NIST CSF 2.0 vs. IEC 62443-2-1. *Overlap.* Both demand governance, risk-based scoping, technical and process controls, incident response, and continuous improvement. CSF 2.0’s *Govern* function maps cleanly onto 62443-2-1’s CSMS chapter; *Identify* maps to asset inventory and risk assessment; *Protect* to the per-zone controls; *Detect/Respond/Recover* to monitoring and IR. Published mapping tables exist (NIST SP 800-82 Rev. 3 includes them).

Conflict. CSF 2.0 is sector-neutral, outcome-based, and explicitly non-certifiable — you cannot be “CSF certified”. 62443-2-1 is OT-specific, prescriptive about process artefacts, and certifiable (ISASecure, IECEE). CSF speaks the language of risk and outcomes (good for boards and insurers); 62443 speaks the language of engineering controls and evidence (good for auditors and procurement). CSF is updated faster (2.0 in 2024); 62443 evolves more slowly and lags emerging tech.

Audience. Use CSF 2.0 for the *board*, the *insurance underwriter*, and any cross-sector communication. Use 62443-2-1 for the *OT engineering team* and the *external auditor*. Most mature programmes operate both — CSF as the executive narrative, 62443 as the engineering backbone — with the SP 800-82 tables as the Rosetta Stone.

Rubric. Award marks for explicitly naming the certifiability difference and for assigning each framework to a defensible audience.

Solution

Exercise 9.10 – KRITIS energy-sector thresholds (open-book, model answer 2026).

Under the current BSI-KritisV (as last substantively amended by the IT-Sicherheitsgesetz 2.0 of 23 May 2021, with the threshold ordinance updated effective 1 January 2022), Anlage 2 covers *Energie* across electricity, gas, district heating, and fuels. Indicative thresholds (verify against current text): electricity generation ≥ 420 MW installed capacity; electricity distribution ≥ 3700 GWh/a delivered or $\geq 100\,000$ connected end-customers; gas transmission/distribution ≥ 5190 GWh/a; district heating $\geq 250\,000$ MWh/a. These thresholds were last lowered as part of the IT-SiG 2.0 package in 2021, applying from 1 January 2022 (BGBl. I S. 1122); the next review is expected to align KRITIS scope with NIS2 categories. Crossing a threshold triggers: mandatory registration with the BSI within six months, application of an industry-specific security standard (B3S Energie), biennial third-party audits, and incident reporting to BSI under § 8b BSIG. *Source:* BSI-Kritisverordnung consolidated text on [gesetze-im-internet.de](https://www.gesetze-im-internet.de); IT-SiG 2.0 BGBl. I 2021 S. 1122; BSI *KRITIS-Sektorenstudien Energie*.

Rubric. Full marks for citing both Anlage 2 thresholds and the 2021/2022 lowering; partial credit if thresholds are off by a factor but the legislative vehicle (IT-SiG 2.0) and the operator consequences (BSI registration, B3S, audits, reporting) are correctly stated. Deduct one point

if no source is cited.